TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

SonicWall will not patch two end-of-life GMS flaws; separate SMA1000 SSRF is under active attack

From **Cybersecurity Briefing** · 2026-11-04 to 2026-11-05 (last 24 hours; Indiana sections swept back to the 2026-10-31 cutoff) · Briefing generated 2026-11-05

REPORT ID	VERSION	HANDLING
CTI-20261105-04	1.0 · 2026-11-05 09:08 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-11-04	No update
CVES	**ANALYST**	
CVE-2026-109593 (CVSS 9.1), CVE-2026-109594 (CVSS 6.8), CVE-2026-102255 (CVSS 10.0)	Nick Sturgeon	

VULNERABILITY | HIGH | UNPATCHED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

SonicWall advisory SNWLID-2026-0019, published 2026-11-03, discloses two flaws in Global Management System (GMS) 9.5.2 and earlier on Windows and Linux, and says no fix will be released because the product is end-of-life [S1] [S2] [S3] [S4]. CVE-2026-109593 (CVSS 9.1) lets an unauthenticated attacker with network access read internal GMS files. CVE-2026-109594 (CVSS 6.8) is a SQL injection that requires a high-privilege account and can expose or change GMS database content [S3] [S4]. GMS support ended 2026-09-30, and SonicWall's only stated remedy is migration to Network Security Manager (NSM) [S1] [S6]. No source we reviewed reports exploitation of either GMS flaw, and CISA's scoring records exploitation as none. CISA also rates the file read as automatable, so an exposed console should be treated as permanently at risk [S3] [S17].

GMS manages large fleets of SonicWall security appliances [S2]. That makes the file read more serious than its data-exposure label suggests, although no source says which files can be read or whether they include credentials or firewall configurations. No exposure count for GMS was found. Instances on 9.5.1 or earlier carry a further problem: the August 2026 advisory covered unauthenticated remote code execution flaws in those versions [S16].

The second issue is separate. CVE-2026-102255 (CVSS 10.0) is a pre-authentication server-side request forgery (SSRF) in the SMA1000 WorkPlace interface, fixed by hotfixes released 2026-10-06 [S5] [S9]. Defused saw traffic against decoys from 2026-10-08, and Previdian's honeypots logged attempts soon after [S8] [S10]. The Hacker News cited 2,541 attempts from eight IPs in Singapore and the U.S. [S1]. When we opened Previdian's page on 2026-11-05 it showed 2,985 attempts, 10 IPs and Albania added as a third source country [S7]. This is honeypot telemetry. It shows attempts, not successful compromises, and Previdian says it could not tell whether any succeeded [S7] [S8]. Canada's Cyber Centre relays the exploitation claim from open sources [S14]. We found no public confirmation of a compromised production appliance, the advisory had not been updated to confirm exploitation when last reported on 2026-10-12, and our check of the CISA KEV catalog version 2026.11.04 found no entry [S10] [S13] [S18]. The briefing's 'under active attack' wording is best read as active exploitation attempts. The risk is still real: earlier 2026 SSRF flaws in the same interface were used to reach credentials, session data and internal networks [S10] [S15].

Defenders should find every GMS instance, remove it from the internet now, restrict it to a management network, audit privileged accounts, and complete the move to NSM or retire it. For SMA1000, confirm build 12.4.3-03670 or later, or 12.5.0-03082 or later. Appliances holding the September fixes remain vulnerable to this flaw [S9]. Any appliance left unpatched and exposed after 2026-10-06 should get a compromise review, not only the hotfix [S15] [S21].

Key judgments

VERY LIKELY · HIGH CONFIDENCE
SonicWall will not release a security fix for CVE-2026-109593 or CVE-2026-109594 in the next 12 months, leaving isolation or retirement as the only risk reduction. [S1] [S2] [S6]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
Exploitation attempts against CVE-2026-109593 will be publicly reported by 2027-02-05. The flaw is unauthenticated, rated automatable and permanently unpatched, and SMA1000 flaws drew attempts within days. Against that, the current EPSS score is low, and no public technical detail or exposure count was found. [S3] [S7] [S10] [S19]

VERY LIKELY · MODERATE CONFIDENCE
Opportunistic attempts against CVE-2026-102255 will continue through at least the end of November 2026. Counts and source IPs both rose in the latest telemetry, although this rests on one sensor operator. [S1] [S7]

LIKELY · MODERATE CONFIDENCE
At least some internet-facing SMA1000 appliances left below the October hotfix will be compromised through this or a chained flaw, even if victims are not publicly named. More than 400 appliances are tracked as exposed, and two earlier 2026 flaw pairs in this product were exploited in real attacks. No compromise tied to this CVE has been confirmed yet. [S8] [S9] [S15]

> **UNLIKELY · LOW CONFIDENCE**
> CISA will add CVE-2026-102255 to the KEV catalog within the next 30 days unless a vendor or incident responder confirms a real compromise. It has remained off the catalog for about four weeks after the first honeypot reports. [S8] [S18]

INDICATORS OF COMPROMISE

No indicators have been published for the GMS flaws, so the only GMS entry is a derived behavior. SMA1000 CVE-2026-102255 indicators come from Previdian as reported in October press, and Previdian's current IP list, paths and user agents are paywalled. Entries marked 'July campaign' come from Rapid7, belong to the earlier CVE-2026-15409/15410 attacks, are months old, and are included only to support compromise reviews of long-exposed SMA1000 appliances.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`146[.]70[.]143[.]142`	Attacker source IP Previdian reported for attempts consistent with CVE-2026-102255. Single-source, seen via secondary reporting because the original post could not be opened. Likely stale, so use for retro-hunting rather than blocking alone.	REPORTED		[S13]
http-request	`HTTP OPTIONS request to the SMA1000 WorkPlace Extraweb interface`	CVE-2026-102255 attempts described by Previdian's founder. The exact URI was not published.	REPORTED		[S8]
http-request	`Path traversal into a CouchDB design document invoking _rewrite`	CVE-2026-102255 payload behavior. Treat as a hunting lead; the literal string in logs may differ.	REPORTED		[S8]
other	`127.0.0.1:5984`	Internal CouchDB service on the appliance that the CVE-2026-102255 payload tried to reach. A loopback address, not attacker infrastructure.	REPORTED		[S8]
port	`5984/tcp`	CouchDB port targeted through the SSRF. It should not be reachable from outside the appliance.	REPORTED		[S8]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`HTTP Basic Authorization header with credentials admin:admin`	Credentials carried in the CVE-2026-102255 payload for the internal CouchDB request. No source reviewed says appliances ship with these credentials.	REPORTED		[S8]
http-request	`Authorization: Basic YWRtaW46YWRtaW4=`	Base64 form of the reported admin:admin pair, which is how the value would appear on the wire or in header logs. Encoded by the analyst.	DERIVED		[S8]
filename	`extraweb_access.log`	Rapid7 used this SMA1000 log for the July /wsproxy activity. Since the October attempts also target the Extraweb interface, it is the likely place to look for them. Not stated for CVE-2026-102255.	DERIVED		[S8] [S15]
other	`Inbound connection to a GMS web console from a source outside the management network`	CVE-2026-109593 requires only network access, so any such connection deserves review. Behavioral only; no exploit path, URI or log signature has been published.	DERIVED		[S3]
ipv4	`45[.]131[.]194[.]0/24`	July campaign (CVE-2026-15409/15410), range in ASN 206092. Not linked to CVE-2026-102255.	REPORTED		[S15]
ipv4	`45[.]146[.]54[.]0/24`	July campaign (CVE-2026-15409/15410), range in ASN 206092. Not linked to CVE-2026-102255.	REPORTED		[S15]
ipv4	`63[.]135[.]161[.]0/24`	July campaign (CVE-2026-15409/15410), range in ASN 206092. Not linked to CVE-2026-102255.	REPORTED		[S15]
ipv4	`173[.]239[.]211[.]0/24`	July campaign (CVE-2026-15409/15410), range in ASN 206092. Not linked to CVE-2026-102255.	REPORTED		[S15]
ipv4	`193[.]37[.]32[.]179`	July campaign (CVE-2026-15409/15410). Not linked to CVE-2026-102255.	REPORTED		[S15]
ipv4	`193[.]37[.]32[.]214`	July campaign (CVE-2026-15409/15410). Not linked to CVE-2026-102255.	REPORTED		[S15]
ipv4	`216[.]73[.]163[.]151`	July campaign (CVE-2026-15409/15410). Not linked to CVE-2026-102255.	REPORTED		[S15]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`216[.]73[.]163[.]158`	July campaign (CVE-2026-15409/15410). Not linked to CVE-2026-102255.	REPORTED		[S15]
other	`ASN 206092 (FNS Holdings Limited)`	July campaign. VPN hosting provider named by Rapid7, which suggests limiting access where there is no business need.	REPORTED		[S15]
other	`DESKTOP-KRLUI3J`	July campaign attacker asset name.	REPORTED		[S15]
other	`DESKTOP-IC3C80F`	July campaign attacker asset name.	REPORTED		[S15]
other	`DESKTOP-5P0TSCP`	July campaign attacker asset name.	REPORTED		[S15]
other	`KALI`	July campaign attacker asset name, seen as a workstation name in NTLM logons. Weak alone.	REPORTED		[S15]
other	`localhost (as attacker asset name)`	July campaign attacker asset name. Very weak alone; useful only with other evidence.	REPORTED		[S15]
http-request	`GET /wsproxy with a host value such as localhost or ::ffff:127.0.0.1`	July campaign. CVE-2026-15409 tunnel activity on WorkPlace port 443.	REPORTED		[S15]
http-request	`GET /wsproxy containing =-3389 with HTTP 101 response`	July campaign. Rapid7 detection pattern for extraweb_access.log.	REPORTED		[S15]
http-request	`/rollbackConfirm.action`	July campaign. Path used for hotfix traversal (CVE-2026-15410).	REPORTED		[S15]
http-request	`/__api__/login or /__api__/logout returning HTTP 200`	July campaign. Rapid7 says these routes are absent from legitimate configurations.	REPORTED		[S15]
http-request	`/__api__/logon/<session-id>/authenticate`	July campaign. Authentication activity Rapid7 flagged for review.	REPORTED		[S15]
http-request	`/auth1.html`	July campaign. Repeated requests flagged as probing.	REPORTED		[S15]
http-request	`/.env`	July campaign. Repeated requests flagged as probing.	REPORTED		[S15]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`/api/sonicos/is-sslvpn-enabled`	July campaign. Repeated requests flagged as probing.	REPORTED		[S15]
filepath	`/usr/local/bin/remove_hotfix`	July campaign. Component in the privilege escalation chain; suspicious when ctrl-service.log shows it called with traversal sequences.	REPORTED		[S15]
filepath	`/tmp/sma1000_5c47.sh`	July campaign. Rapid7's example of a /tmp script name referenced in traversal payloads; names may vary.	REPORTED		[S15]
filepath	`/tmp/temp.db*`	July campaign. Linked to session data access.	REPORTED		[S15]
filepath	`/var/lib/unit/conf.json`	July campaign. Suspicious if it contains /__api__/login or /__api__/logout routes.	REPORTED		[S15]
port	`1050/tcp`	July campaign. Localhost Erlang process Rapid7 targeted to run code as the couchdb user.	REPORTED		[S15]
port	`8188/tcp`	July campaign. Port through which ctrl-service can be reached for the remove_hotfix traversal.	REPORTED		[S15]
other	`Event ID 4624, logon type 3, NTLM to a domain controller from the appliance's internal IP with no matching VPN session`	July campaign lateral movement pattern. Useful in any SMA1000 compromise review.	REPORTED		[S15]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The GMS flaws have no published attack details. From the advisory wording, an attacker able to reach a GMS console could read internal files without logging in (CVE-2026-109593), and a holder of a high-privilege account could read or alter database content through SQL injection (CVE-2026-109594) [S3] [S4]. Whether stolen files could yield the high-privilege access needed for the second flaw is our inference, not a reported chain. The SMA1000 activity is different and better described: attempts send a crafted OPTIONS request to the WorkPlace

Extraweb interface, using the SSRF to reach internal CouchDB on 127.0.0.1:5984 with admin:admin Basic credentials and a traversal to a design document's _rewrite function [S8]. Success has not been confirmed. Earlier 2026 attacks on the same product show the possible follow-on: tunnel to internal services, run commands as the couchdb user, escalate to root, take credentials, session data and TOTP seeds, then move into the internal network [S10] [S15]. Those later steps are from the July campaign and have not been observed for CVE-2026-102255.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1595.002 Active Scanning: Vulnerability Scanning	Honeypots logged attempts against CVE-2026-102255 from a small set of IPs, starting about two days after disclosure. [S7] [S10]	Review WorkPlace logs for unusual OPTIONS requests from a few repeat sources.
Initial Access	T1190 Exploit Public-Facing Application	Pre-auth SSRF in SMA1000 WorkPlace (CVE-2026-102255). The unauthenticated GMS file read (CVE-2026-109593) would fit here if a console is exposed, but no use is reported. [S3] [S5] [S8]	Web and reverse proxy logs; external scans of your own ranges to confirm exposure and build level.
Command and Control	T1090.001 Proxy: Internal Proxy	The appliance is made to send requests on the attacker's behalf to internal functionality, with CouchDB on loopback as the observed target. [S5] [S8]	Extraweb logs showing internal or loopback targets; unexpected outbound connections from the appliance.
Defense Evasion	T1078.001 Valid Accounts: Default Accounts	The SMA1000 payload tries admin:admin against internal CouchDB. Whether this works on any production appliance is unknown. [S8]	Basic Authorization headers decoding to admin:admin, where headers are logged or TLS is decrypted.
Collection	T1005 Data from Local System	CVE-2026-109593 allows reading of internal GMS files. Mapped from the advisory description; no in-the-wild use is reported. [S3]	GMS web server logs for unauthenticated requests that return unusually large or non-page responses.
Credential Access	T1552.001 Unsecured Credentials: Credentials In Files	Possible outcome of the GMS file read if readable files hold secrets. Analyst inference; sources say only that sensitive information could be exposed. [S3]	Unexpected logins to GMS or managed devices following any external access to the console.

Tactic	Technique	Procedure observed	Detection opportunity
Impact	T1565.001 Data Manipulation: Stored Data Manipulation	CVE-2026-109594 lets a high-privilege user modify GMS database content under specific conditions. No use is reported. [S4]	Database audit logs and unexplained changes in GMS records; SQL syntax errors in application logs.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	July campaign only: scripts run from /tmp and commands run via the internal Erlang service as the couchdb user. [S15]	Unexpected scripts in /tmp and new child processes of the couchdb user, in an appliance review.
Privilege Escalation	T1068 Exploitation for Privilege Escalation	July campaign only: traversal in the remove_hotfix workflow (CVE-2026-15410) ran an attacker script as root. [S15]	ctrl-service.log entries showing remove_hotfix with traversal sequences; unplanned reboots.
Persistence	T1505.003 Server Software Component: Web Shell	Earlier 2026 campaign only: Java web shells deployed on SMA1000 appliances. [S10] [S15]	File integrity review and rogue routes in /var/lib/unit/conf.json.
Credential Access	T1539 Steal Web Session Cookie	July campaign only: active session databases and TOTP MFA seed configurations were taken, helping access survive network-level cleanup. [S10] [S15]	Access to /tmp/temp.db* and sessions without a matching user login.
Lateral Movement	T1021 Remote Services	July campaign only: NTLM network logons to domain controllers from the appliance's internal IP. [S15]	Event ID 4624 type 3 from the appliance IP without a matching VPN session.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

SMA1000 WorkPlace: possible CVE-2026-102255 attempts `SPLUNK SPL`

```
index=network_appliance sourcetype=sma1000:extraweb_access
("OPTIONS" AND ("_rewrite" OR "_design" OR "5984" OR "couchdb"))
| stats count min(_time) as first_seen max(_time) as last_seen values(uri) as uris by src_ip, host
| sort - count
```

Index, sourcetype and field names are placeholders. The exact URI is not public, so review broad OPTIONS results by hand if nothing matches. Hunt from 2026-10-06 onward. A hit shows an attempt, not success.

OPTIONS request carrying admin:admin Basic credentials `SURICATA`

```
alert http any any -> $HOME_NET any (msg:"Possible SMA1000 CVE-2026-102255 attempt - OPTIONS with admin:admin Basic auth"; flow:established,to_server; http.method; content:"OPTIONS"; http.header; content:"Basic YWRtaW46YWRtaW4="; classtype:web-application-attack; sid:9102255; rev:1;)
```

Needs decrypted traffic, for example behind TLS inspection, because WorkPlace runs on HTTPS. Choose a sid that fits your local range. The header may also appear in the decoded inner request rather than the outer one.

Domain controller logons sourced from the SMA1000 internal IP `KQL`

```
let ApplianceIPs = dynamic(["<SMA1000_INTERNAL_IP>"]);
SecurityEvent
| where TimeGenerated > ago(120d)
| where EventID == 4624 and LogonType == 3 and AuthenticationPackageName == "NTLM"
| where IpAddress in (ApplianceIPs)
| summarize Count=count(), First=min(TimeGenerated), Last=max(TimeGenerated) by Computer, Account, WorkstationName, IpAddress
| sort by Last desc
```

From the July campaign pattern. Compare results with VPN session logs and legitimate authentication flows from the appliance. Filter Computer to your domain controllers.

GMS console reached from outside the management network `KQL`

```
let GmsHosts = dynamic(["<GMS_IP>"]);
let MgmtNets = dynamic(["<MGMT_CIDR>"]);
CommonSecurityLog
| where TimeGenerated > ago(90d)
| where DestinationIP in (GmsHosts) and DestinationPort in (80, 443)
| where not(ipv4_is_in_any_range(SourceIP, MgmtNets))
| summarize Count=count(), First=min(TimeGenerated), Last=max(TimeGenerated) by SourceIP, DestinationIP, DestinationPort
| sort by Count desc
```

No exploit signature exists for CVE-2026-109593, so this checks exposure only. Replace the ports with the ones your GMS actually uses; they are assumptions here. Any result supports the case for isolation and secret rotation.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
SonicWall Global Management System (GMS), Windows and Linux	9.5.2 and earlier	None; end-of-life. Migrate to NSM	CVE-2026-109593	9.1 (CISA ADP)	0.00521 (44th percentile, 2026-11-04)	No	N/A
SonicWall Global Management System (GMS), Windows and Linux	9.5.2 and earlier	None; end-of-life. Migrate to NSM	CVE-2026-109594	6.8 (CISA ADP); VulDB reportedly 6.3	0.00381 (32nd percentile, 2026-11-04)	No	N/A
SonicWall SMA1000 6210, 7210, 8200v	12.4.3-03526 and older; 12.5.0-02952 and older	12.4.3-03670 or higher; 12.5.0-03082 or higher	CVE-2026-102255	10.0	0.00981 (62nd percentile, 2026-11-04)	No	N/A

Immediate (0–24 hours)

- Inventory every GMS instance at 9.5.2 or earlier, on Windows and Linux, including lab, disaster recovery and MSP-managed consoles. `IT OPS` [S20]
- Remove all internet exposure of GMS and restrict access to a dedicated admin network or bastion host. This reduces risk but does not fix the flaws. `IT OPS` [S17] [S20]
- Check each SMA1000 build. Install the October hotfix from MySonicWall if it is below 12.4.3-03670 or 12.5.0-03082, and plan for the appliance restart. Appliances on the September fix builds still need it. `IT OPS` [S9] [S12]
- Export SMA1000 logs from at least 2026-10-06 before patching so evidence is kept. Analyst recommendation, since a restart follows installation and retention on the appliance may be limited. `SOC` [S8] [S9]
- Hunt SMA1000 logs for the OPTIONS, CouchDB and _rewrite leads and for the reported source IP. Treat any hit as an attempt until other evidence shows success. `SOC` [S8] [S13]

Short term (1–7 days)

- Audit and reduce privileged GMS accounts, rotate their credentials, and enforce MFA where possible. `IT OPS` [S17] [S20]
- If GMS was ever reachable from untrusted networks, rotate secrets stored in or accessible through it, including credentials for managed firewalls, and check the database for unexplained changes. `SOC` [S2]

[S20]

- Prioritize any GMS on 9.5.1 or earlier, which the August 2026 advisory lists as affected by unauthenticated code execution flaws. Isolate it first and review it for compromise. SOC [S16] [S17]
- Review any SMA1000 exposed and unpatched after 2026-10-06, or never reviewed after the July or September flaws. If compromise is found, rebuild from a clean fixed image, then change user and admin passwords and reset TOTP tokens. SOC [S15] [S21]
- Begin the GMS to NSM migration. SonicWall offers NSM SaaS and on-premises options; a GMS Transition Snapshot can reportedly carry firewall management data into NSM On-Prem. IT OPS [S6] [S17]

Long term

- Complete migration and decommission all GMS servers. Securely wipe or retain their data according to policy, because the databases and files may hold sensitive configuration. IT OPS [S1] [S6]
- Fund and approve an end-of-support replacement plan for security and management products, with lifecycle dates tracked. GMS gave about 17 months' notice before support ended. LEADERSHIP [S6]
- Assess continued use of SMA1000 and how much it trusts internal networks, given three no-login WorkPlace SSRF fixes in 2026. Require a formal risk decision for keeping it internet-facing. LEADERSHIP [S9]

Workarounds & compensating controls

- Until GMS is retired, segment it from other networks, manage it only from dedicated administrative systems, and alert on any connection from outside that path. IT OPS [S16] [S20]
- Limit SMA1000 WorkPlace to required source networks where possible, and keep the Appliance Management Console off internet-reachable segments. This does not replace the hotfix, and SonicWall lists no workaround. IT OPS [S13] [S21]
- Restrict outbound access from SMA1000 and GMS hosts and alert on domain controller logons from the appliance outside expected VPN flows. SOC [S15]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: SonicWall Won't Patch EoL GMS Flaws That Could Expose Files, Alter Database Records
Published 2026-11-04 · B2 Usually reliable, probably true
Briefing source. Quotes the vendor and cites the 2,541-attempt Previdian figure.

[S2] BleepingComputer: SonicWall warns of unpatched flaws in end-of-life GMS software
Published 2026-11-04 · B2 Usually reliable, probably true
Article behind the briefing's front-page headline link. Source for GMS role and KEV history counts.

[S3] CVE Program: CVE-2026-109593 record
Published 2026-11-03 · **A1** Completely reliable, confirmed by other sources
Primary. Includes vendor text, CISA ADP score and SSVC.

[S4] CVE Program: CVE-2026-109594 record
Published 2026-11-03 · **A1** Completely reliable, confirmed by other sources
Primary. Includes vendor text, CISA ADP score and SSVC.

[S5] CVE Program: CVE-2026-102255 record
Published 2026-10-07 · **A1** Completely reliable, confirmed by other sources
Primary. Its SSVC exploitation value of none dates from 2026-10-07, before the honeypot reports.

[S6] SonicWall: GMS EOL Announcement
Published 2025-05-05 · **A1** Completely reliable, confirmed by other sources
Primary vendor lifecycle notice. Publication date taken from the stated announcement date.

[S7] Previdian: CVE-2026-102255 telemetry page
Published 2026-11-05 · **B3** Usually reliable, possibly true
Original sensor data from two sensors; a live counter viewed 2026-11-05. Shows attempts only. IPs, paths and user agents are paywalled.

[S8] BleepingComputer: Max severity SonicWall SMA1000 flaw now exploited in attacks
Published 2026-10-09 · **B2** Usually reliable, probably true
Best public technical description of the attempts, via Previdian's founder. Also the source for the Shadowserver count.

[S9] The Hacker News: SonicWall patches CVSS 10.0 pre-auth SMA1000 flaw
Published 2026-10-07 · **B2** Usually reliable, probably true
Fix table and advisory detail. Title paraphrased from the content retrieved.

[S10] The Hacker News: Critical SonicWall SMA 1000 flaw exploited after patch
Published 2026-10-12 · **B2** Usually reliable, probably true
Reports 135 attempts from two U.S. IPs, and the earlier campaign detail.

[S11] SecurityWeek: Critical SonicWall Vulnerability Exploited Days After Disclosure
Published 2026-10-12 · **B2** Usually reliable, probably true
Independent confirmation of Defused and Previdian warnings; also cites Horizon3.ai.

[S12] Help Net Security: SonicWall fixes pre-auth SSRF flaw in SMA 1000 appliances (CVE-2026-102255)
Published 2026-10-07 · **B2** Usually reliable, probably true
Quotes vendor no-exploitation statement. Updated 2026-10-12 with Defused's report.

[S13] Security Affairs: SonicWall Patches CVSS 10.0 SSRF Flaw as Attacks Begin
Published 2026-10-12 · **C3** Fairly reliable, possibly true
Only opened source carrying the reported IP. The original Previdian post on X returned HTTP 402 and could not be read.

[S14] Canadian Centre for Cyber Security: SonicWall security advisory (AV26-1017) - Update 1
Published 2026-10-07 · **A3** Completely reliable, possibly true
Updated 2026-10-09. Relays exploitation from open sources. Its version wording lists fixed builds as affected, which conflicts with the CVE record.

[S15] Rapid7: Rapid7 MDR team discovers new SonicWall SMA1000 zero-days being actively exploited (CVE-2026-15409, CVE-2026-15410)
Published · **A1** Completely reliable, confirmed by other sources
Original incident response write-up on the July campaign. Context only; not evidence about CVE-2026-102255. Exact publication date not captured.

[S16] CIS / MS-ISAC: Multiple Vulnerabilities in SonicWall GMS Could Allow for Remote Code Execution (2026-083)
Published 2026-08-11 · **A1** Completely reliable, confirmed by other sources
August GMS flaws under SNWLID-2026-0011; no exploitation reported at the time.

[S17] IT-Connect: SonicWall GMS: two flaws, including a critical one, will never be fixed
Published 2026-11-05 · **C2** Fairly reliable, probably true
Newest coverage found. Reports no exploitation indication, no workaround, and the transition snapshot. Title paraphrased from the URL.

[S18] CISA: Known Exploited Vulnerabilities Catalog, version 2026.11.04
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
Newest-first feed. Portion reviewed runs back to 2026-09-18, before all three CVEs existed publicly, and shows no SonicWall entries.

[S19] FIRST: EPSS API results for the three CVEs
Published 2026-11-04 · **A2** Completely reliable, probably true
Model output, not evidence of exploitation. New CVEs may be under-scored.

[S20] WindowsForum: SonicWall GMS CVE-2026-109593 and CVE-2026-109594: No Patches for EOL Software, Migrate to NSM
Published 2026-11-04 · **C3** Fairly reliable, possibly true
Secondary. Practical interim steps and the VulDB score discrepancy. It labels its restriction advice as general practice, not vendor guidance.

[S21] WindowsForum: CVE-2026-102255 SonicWall SMA1000 SSRF Exploit Attempts: Patch WorkPlace Now
Published · `C3` Fairly reliable, possibly true
Secondary. Relays exposure-reduction and rebuild advice attributed to CSA, noting SonicWall has not issued that instruction for the October flaws.

[S22] NVD: CVE-2026-109593 API record
Published 2026-11-03 · `A1` Completely reliable, confirmed by other sources
Awaiting Analysis, no KEV fields. The NVD records for the other two CVEs were also checked and show the same status.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2025-05-05	SonicWall announces GMS end-of-life.	[S6]
2025-10-01	GMS last day of order.	[S6]
2026-07-14	SonicWall discloses SMA1000 CVE-2026-15409 and CVE-2026-15410, exploited as zero-days.	[S9] [S15]
2026-08-11	Advisory covers six GMS flaws in 9.5.1 and earlier, including unauthenticated code execution.	[S16]
2026-09-01	SonicWall discloses a further exploited SMA1000 pair, CVE-2026-83548 and CVE-2026-83549.	[S9]
2026-09-30	GMS last day of support.	[S6]
2026-10-06	SNWLID-2026-0017 and SMA1000 hotfixes released; vendor reports no evidence of exploitation.	[S9] [S12]
2026-10-07	CVE-2026-102255 record published.	[S5]
2026-10-08	Defused sees first unauthenticated SSRF traffic against SMA decoys.	[S11] [S12]

Date	Event	Source
2026-10-09	Previdian's first recorded attempt and public warnings; Canada's Cyber Centre updates its advisory.	[S7] [S8] [S14]
2026-10-12	Reporting cites 135 attempts from two U.S. IPs; advisory not updated to confirm exploitation.	[S10]
2026-11-03	SNWLID-2026-0019 and both GMS CVE records published. Up to 30 SMA1000 attempts recorded that day.	[S1] [S3] [S4]
2026-11-04	Coverage cites 2,541 attempts from eight IPs. CISA KEV version 2026.11.04 released with no SonicWall addition in the period reviewed.	[S1] [S18]
2026-11-05	Previdian page shows 2,985 attempts, 10 IPs and three source countries, last observed 2026-11-04.	[S7]

Relevance to Indianapolis, Indiana & managed clients

No source we reviewed mentions an Indiana victim or Indiana-specific activity. The exposure question for local organizations is practical: GMS is often the kind of long-lived management server that stays running after a support date passes, and support ended only five weeks before this advisory. Government agencies, school districts, healthcare groups and manufacturers across Indianapolis and Indiana running SonicWall firewalls should confirm whether an old GMS still exists, including at remote or acquired sites. Smaller organizations may have no one assigned to the console and may rely on a partner to check it, while budget cycles at public bodies could delay an NSM purchase; isolation should not wait for that decision. For managed IT service clients, a shared GMS console would concentrate risk, since it manages many appliances across customers. Providers should list every console they run or inherited, confirm it is not reachable from the internet, and tell clients in writing about the end-of-support status. SMA1000 is used by medium to large enterprises, MSPs and government agencies [S12], so its owners should verify the October hotfix now. Healthcare and public sector organizations should also consider whether a stolen TOTP seed or session database, as seen in the July campaign, would affect their incident notification duties [S15].

Intelligence gaps

- We could not read SonicWall's advisories SNWLID-2026-0019 and SNWLID-2026-0017 directly because the pages returned only a title. Their content comes from the CVE records and press quotes. Recheck them for changes, especially any exploitation update to 0017.
- Which GMS files CVE-2026-109593 can read, and whether they contain credentials or managed-device configuration, is not public. No exploit path, proof of concept or Pentest-Tools write-up was found; watch for one, since it would raise the risk quickly.
- No count of internet-exposed GMS instances was found. Shadowserver's count of more than 400 covers SMA1000 only and includes an unknown share of patched devices and honeypots.
- Whether any CVE-2026-102255 attempt has succeeded against a production appliance is unknown. Telemetry comes from honeypots and does not test whether targets were vulnerable.
- The other Previdian source IPs, five request targets and five user agents sit behind a paid tier, so the indicator list is incomplete.

- No actor has been tied to CVE-2026-102255 or the GMS flaws. Watch for overlap with the groups behind earlier SMA1000 attacks.
- KEV status rests on the 2026.11.04 catalog. Recheck it against each new release.

Other notes

- Telemetry changed after the briefing excerpt: 2,541 attempts from eight IPs in Singapore and the U.S. [S1] became 2,985 attempts from 10 IPs including Albania on Previdian's live page [S7]. These are moving counts over a rolling window, from two sensors.
- First-activity dates differ slightly. Defused reports 2026-10-08 [S11] [S12], while Previdian's page and the 2026-11-04 coverage use 2026-10-09 [S1] [S7]. These may reflect different sensor networks. The Hacker News also credits Previdian with signs from 2026-10-08 [S10].
- Sources differ on the word 'exploited'. Press headlines say exploited, while Previdian says attempts and could not determine success [S7] [S8], and SonicWall's advisory said no evidence of exploitation when issued [S12]. CISA's SSVC value of none predates the reports [S5].
- Canada's advisory lists 12.4.3-03670 and 12.5.0-03082 'and prior' as affected, while the CVE record lists 12.4.3-03526 and 12.5.0-02952 and older [S5] [S14]. We follow the CVE record and treat 03670 and 03082 as fixed [S9].
- The CVSS 9.1 vector for CVE-2026-109593 rates availability as High and integrity as None, while the description covers only file read. Its CWE-636 (Not Failing Securely) also gives no clear mechanism [S3]. The availability impact is unexplained. VulDB reportedly scores CVE-2026-109594 at 6.3 rather than 6.8 [S20].
- The GMS flaws were reported by Matei Badanoiu (both) and Andrei Lungu (CVE-2026-109594) of Pentest-Tools.com [S3] [S4]. CVE-2026-102255 was credited to Benoit Sevens of Anthropic in press reporting [S9].
- SNWLID-2026-0017 also fixed CVE-2026-102256 (admin OS command injection, 7.8), CVE-2026-102257 (Zip Slip, 7.2) and CVE-2026-102258 (stored XSS, 5.5). SonicWall has not said whether the SSRF can chain with them [S9].
- Earlier SMA1000 activity is context, not attribution. The July attacks are tied to a cluster tracked as UTA0533 with Java web shells and KNUCKLEBALL malware [S10], while other reporting names Sou5, OrangeTail and RootRun and says CISA linked some attacks to ransomware groups [S8]. No source connects these to the current attempts.
- BleepingComputer counts 19 SonicWall flaws added to KEV over four years, 13 tied to ransomware use [S2]. Horizon3.ai warned, via SecurityWeek, that successful exploitation could allow device takeover [S11].

CTI-20261105-04 v1.0 · Generated 2026-11-05 09:08 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.